

メルカリのClaude Codeセキュリティ設定の組織配布戦略

Claude Code Meetup Tokyo 2026

株式会社メルカリ Hiroki Akamatsu

mercari

Claude Code活用に潜むリスク

主な機能

- ファイルの検索や読み書き編集
- Web検索 & ページ取得
- コマンドを実行 → 任意の行動をできる (rm -rf, curl)

PC上に存在しうるアセット

- 大事なファイル
- 認証情報

→ オンラインストレージを基本・認証情報の短期化でも依然リスクあり

mercari

4

Claude Codeのセキュリティ向上設定

- 人間による確認を行う
→ パーミッションモードのbypassを禁止
- 大事なコマンドは確認を必須
→ bashのインライン実行やcurlは確認を必須
- 危険な行動は禁止
→ 環境変数の管理ファイルの読み込み禁止
→ AIによるシステム変更(sudo)の禁止
- Sandboxによるディレクトリ外およびネットワークの制限
→ ディレクトリ外操作を禁止・ネットワーク制限による漏洩防止
- 会社のセキュリティポリシーを教える
→ システムプロンプトに追加

どうやって全社員に展開する？

mercari

5

Claude Codeのセキュリティ設定の展開

MDM (端末管理) を使った一斉展開

- Claude Code設定
- システムプロンプト

MDM-level policies delivered through native device management on macOS and Windows

- macOS: gas.authinfo.plist, ClaudeCode managed preferences domain (deployed via configuration profiles in Jamf, Kandji, or other MDM tools)
- Windows: HKLM\SOFTWARE\Policies\ClaudeCode registry key with a Settings value (REG_SZ or REG_EXPAND_SZ) containing JSON (deployed via Group Policy or Intune)
- Windows (user-level): HKCU\SOFTWARE\Policies\ClaudeCode (lowest policy priority, only used when no admin-level source exists)

Claude Code settings

Scope	Location	Purpose
Managed policy	macOS: /Library/Application Support/ClaudeCode/CLAUSET-SET Linux and WSL: /etc/claudecode/claudecode-SET-SET Windows: C:\Program Files\ClaudeCode\CLAUSET-SET	Organization-wide instructions managed by IT/DevOps

Deploy organization-wide CLAUDE.md

mercari

6

Claude Codeセキュリティ設定の組織配布

最高優先度で扱われるMDM配布設定

- カスタマイズをしたい・コマンド知識のあるエンジニア
- 最初から安全な設定が欲しい非エンジニア

MDMに連携した情報から配布設定を分離

エンジニア

安全性を確保
カスタマイズが可能な設定

非エンジニア

実現できうる最も安全な設定
カスタマイズなしで安全な状態を提供

MDMで配布設定を分離

→ それぞれが生産性高く安全に利用できる環境を実現

mercari

1

メルカリのAI活用を支えるAIセキュリティ

AI Security Conference

株式会社メルカリ Choi Chun Ming

mercari

1

AI活用の支え方

“大規模環境”で

AI活用に全力を出しながら安全さを保つには？

→ Secure by DefaultなAIプラットフォーム

mercari

15

AI活用を支えるプラットフォーム

社内全体での安全なAI活用を支えるプラットフォーム

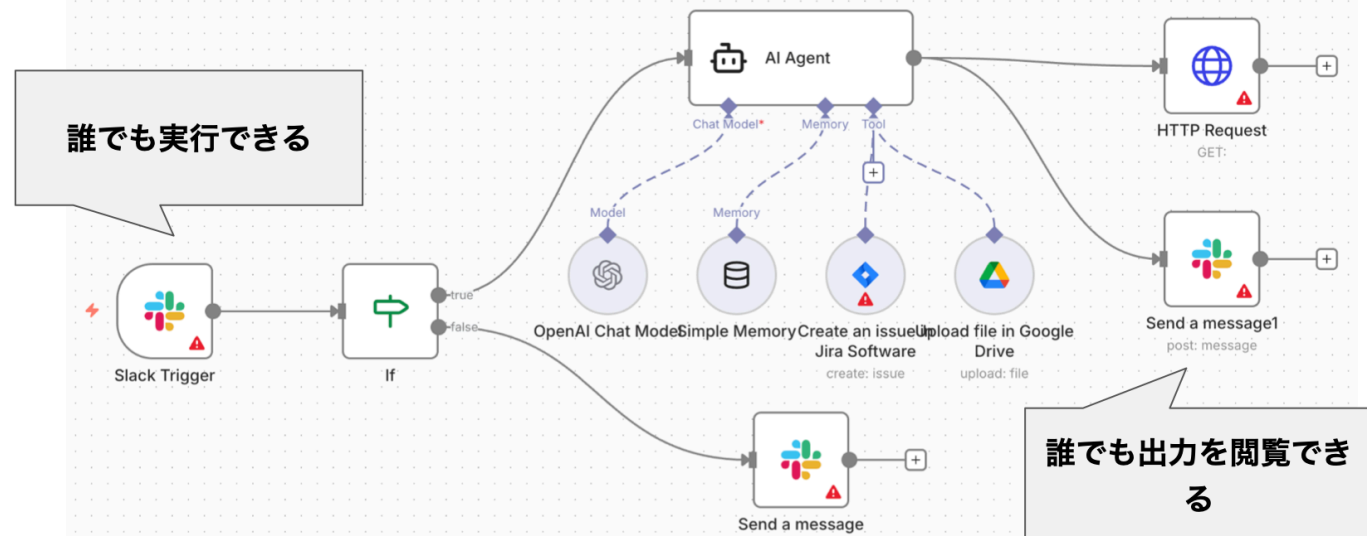
- n8nワークフローの自動セキュリティ検査
 - 短期間のLLM API認証情報を提供するLiteLLM基盤
 - Policy BotによるAI Agent時代のソースコード基盤強化
- メルカリの大規模なAI活用を支える「面」のセキュリティ対策事例

※ 例であり、そのままの導入を推奨するものではありません。

mercari

16

1. Secure by Defaultではないワークフロー

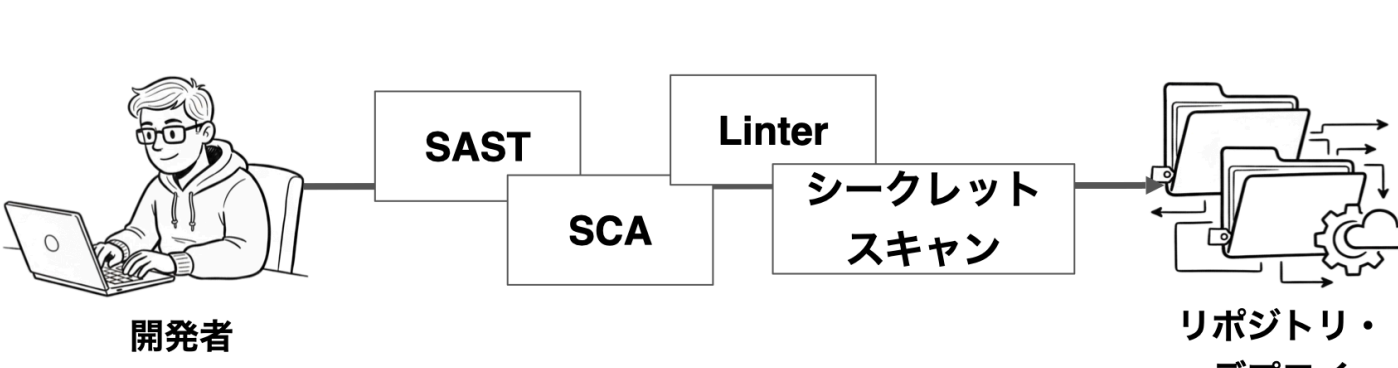


mercari

22

1. n8nのセキュリティ課題

一般のアプリケーション開発では...



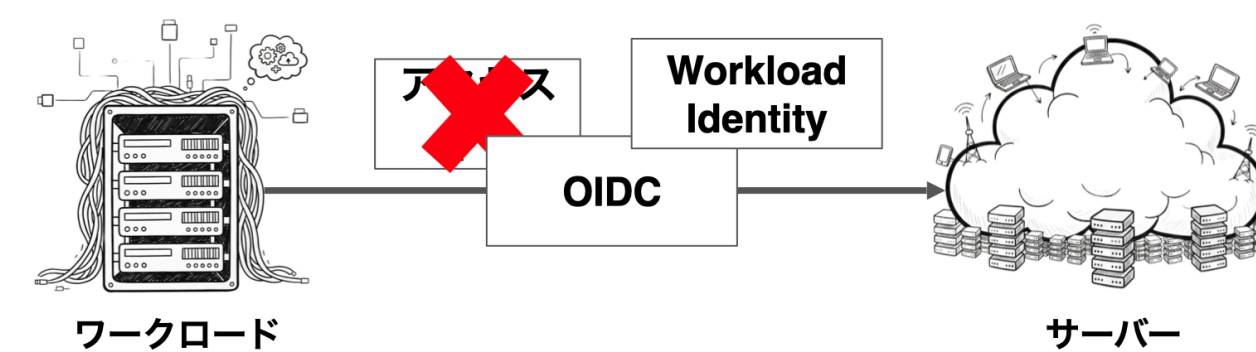
セキュアな開発を開発者に任せるのではなく
自動チェックによるセキュリティのシフトレフト

mercari

24

2. LLMモデルへのアクセス権限付与

クラウドでは...



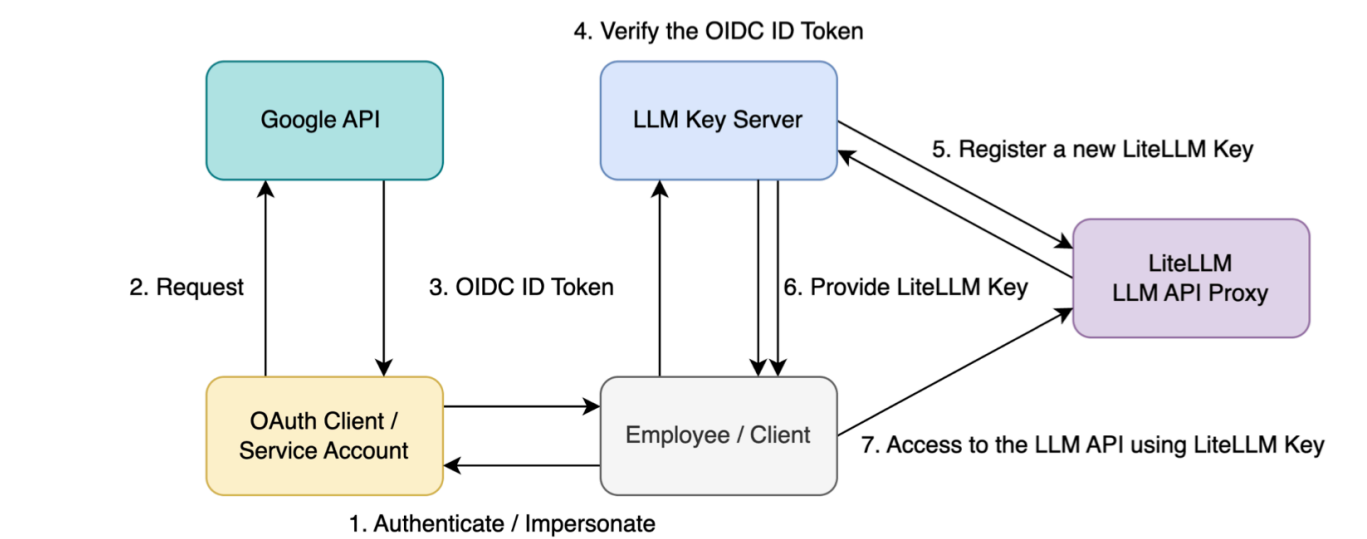
長期的な認証情報は管理が困難
短期トークンでリスク最小化

mercari

31

2. LiteLLM Key Server

社内メンバー判定 + LiteLLMの管理API操作する管理コンポーネント

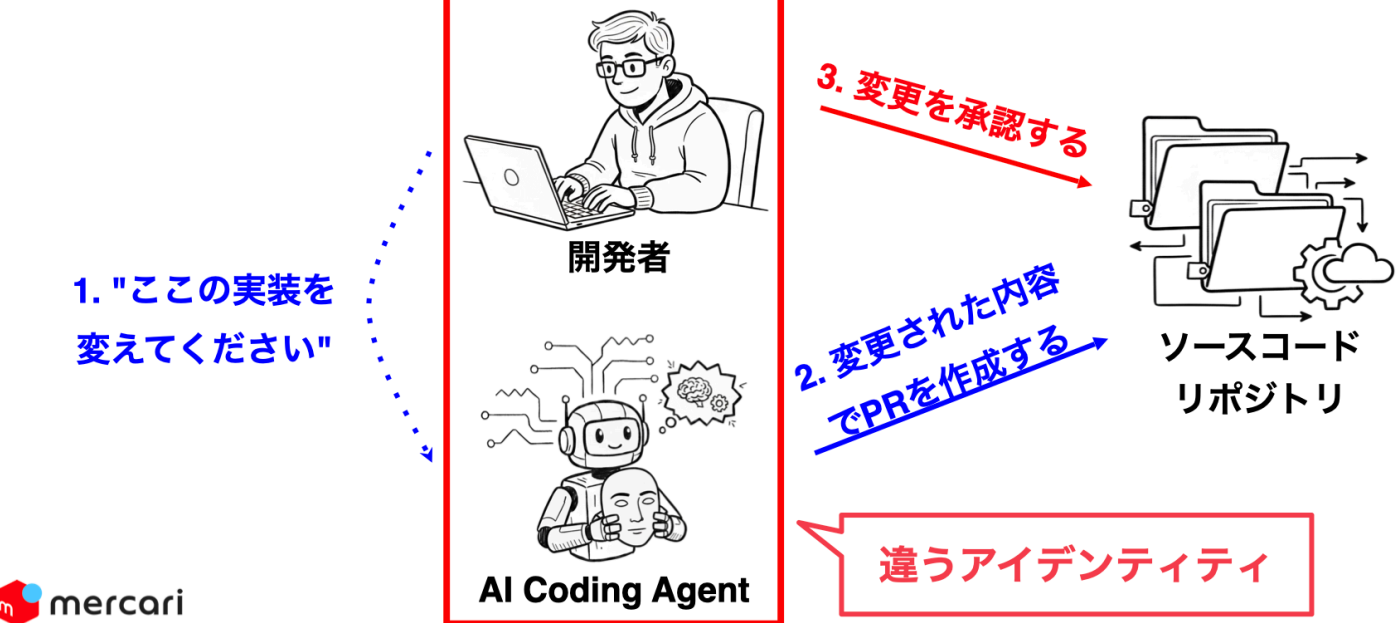


mercari

35

3. AI Agent時代のソースコード基盤強化

しかし、内容だけではなく、アイデンティティにも注目



mercari

41

3. Policy Botの考え方

AI Coding Agentに依頼した変更を他の開発者のレビュー必須にしたい
(セグリゲーション segregation of duties)

→ そういったPRのみに、2つのレビューを必須にする

→ Policy Botの柔軟なポリシーエンジンによって実現

```
policy:
  approval:
    - or:
      - developer
      - fallback
  approval_rules:
    - name: developer
      if:
        only_has_contributors_in:
          teams: ["developers"]
      requires:
        count: 1
    - name: fallback
      requires:
        count: 2
```

mercari

46